

Bloc 2

Script, plan de secours et réponses au jury

Repère	Support
ORAL-01	Guide de lecture du jury
ORAL-02	Script chronométré de soutenance
ORAL-03	Plan de secours de démonstration
ORAL-04	Questions-réponses du jury

Support de préparation du candidat - ne pas joindre au dépôt sauf demande explicite du campus.

Sommaire

ORAL-01 - Guide de lecture du jury	3
Lecture recommandée	3
Repères factuels	3
Matrice des neuf compétences	4
Réserve et contrôle CI/CD à lire avant l'oral	4
Vérification d'intégrité	5
ORAL-02 - Script chronométré de soutenance	6
Avant de commencer	6
Déroulé chronométré	6
Discipline de preuve pendant les questions	8
ORAL-03 - Plan de secours de démonstration	9
Préparation	9
Niveaux de démonstration	9
Incidents et bascule probatoire	10
Ordre minimal en cas de temps réduit	10
Après l'oral	10
ORAL-04 - Questions-réponses du jury	11
Questions sur les compétences éliminatoires	11
Sécurité et architecture	11
CI/CD, versions et preuves	12
Choix et limites d'ingénierie	12

ORAL-01 - Guide de lecture du jury

Document d'orientation, sans donnée personnelle.

Version applicative présentée : 0.13.0-rc.3.

Baseline applicative testée et déployée :

b002adb0e0e7d8d85ee493d54879e190d77d2078 (b002adb).

Référence documentaire : tag rncp-bloc2-2026-07-21-v7.

Le SHA exact de la source archivée figure dans le MANIFESTE.txt du paquet.

Lecture recommandée

1. Lire la synthèse et la matrice finale du dossier principal, sections 2 et 17.
2. Examiner en priorité les quatre compétences éliminatoires : C2.2.1, C2.2.2, C2.2.3 et C2.3.1.
3. Utiliser la matrice ci-dessous pour passer du critère à la preuve primaire.
4. Consulter le cahier de recettes pour distinguer les 58 scénarios clos de l'unique réserve CR-055.
5. Vérifier dans le MANIFESTE.txt du paquet que la source, les deux PDF et les empreintes appartiennent au même gel documentaire.

La décision d'acquisition appartient au jury. Les états « étayé » ci-dessous signifient seulement qu'une chaîne de preuves vérifiable est fournie.

Repères factuels

Repère	Valeur à vérifier
Compétences du bloc	9
Compétences éliminatoires	C2.2.1, C2.2.2, C2.2.3 et C2.3.1
Cahier de recettes	59 scénarios : 58 clos, 1 réservé
Baseline de production	b002adb
CI canonique	GitHub Actions 29845956008, six jobs verts
CD canonique	GitHub Actions 29846343559, smoke tests Web/API verts
Tests des suites complètes	shared 14, API 170, Web 55 ; périmètre PostgreSQL RNCP 9 contrôles
Accessibilité finale	33/33 contrôles, zoom natif 16/16 ; portée humaine non exhaustive
Documentation d'exploitation	manuel de déploiement, manuel utilisateur et manuel de mise à jour

Matrice des neuf compétences

Compétence	Ce que le jury doit pouvoir établir	Point d'entrée	Preuves primaires	État et limite
C2.1.1 - Environnements, qualité et performance	Les environnements et objectifs sont définis, reproductibles et mesurés.	Dossier, sections 3 et 5	B2-A21, B2-A22, B2-A28, B2-A29 ; docs/deployment.md	Étayé. A29 est une mesure séquentielle, pas un test de charge distribué.
C2.1.2 - Intégration continue	Chaque changement traverse des gates qualité, tests, audit, build et images.	Dossier, section 4	.github/workflows/ci.yml, B2-A23, B2-A27, B2-A28, B2-A38 ; CI 29845956008	Étayé. Les rapports séparent suites complètes et tests instrumentés pour la couverture.
C2.2.1 - Prototype fonctionnel	Les parcours essentiels fonctionnent sur une interface responsive et protégée.	Dossier, section 7	B2-A25, B2-A30, captures bureau/mobile, recette CR-065	Éliminatoire - étayé. La démonstration doit rester centrée sur les parcours réellement observés.
C2.2.2 - Tests unitaires	Les règles métier et composants critiques sont vérifiés avec des résultats mesurables.	Dossier, section 8	B2-A19, B2-A28, B2-A31 ; rapports de couverture	Éliminatoire - étayé. 155 API, 43 Web, 8 PostgreSQL et 14 shared sont instrumentés ; les suites complètes comptent 170 API, 55 Web, 9 PostgreSQL RNCP et 14 shared.
C2.2.3 - Sécurité, accessibilité et conformité	Les risques principaux ont des contrôles exécutés et les limites ne sont pas masquées.	Dossier, sections 9 et 10	B2-A23 à A30, B2-A35, B2-A36, B2-A37 ; revue OWASP	Éliminatoire - étayé avec limite humaine. Aucun audit RGAA exhaustif ni parcours avec lecteur d'écran réel n'est revendiqué.
C2.2.4 - Déploiement progressif et versionnement	Une baseline identifiée passe de la CI au CD avec migration et smoke tests.	Dossier, section 11	B2-A22, B2-A28, B2-A38 ; docs/ci-cd.md ; CD 29846343559	Étayé. b002adb est le SHA applicatif ; le SHA documentaire est distinct.
C2.3.1 - Cahier de recettes	Les exigences sont traduites en scénarios, résultats et preuves auditable.	Dossier, section 12	B2-A12, B2-A25, B2-A30, B2-A34 à A38	Éliminatoire - étayé avec une réserve. 58/59 clos ; seule CR-055 reste explicitement bornée.
C2.3.2 - Correction des bogues	Les anomalies sont reproduites, priorisées, corrigées et contre-testées.	Dossier, section 13	B2-A13, B2-A25, B2-A27, B2-A34, B2-A36 à A38	Étayé. Le registre distingue correction observée, automatisation et risque accepté.
C2.4.1 - Documentation d'exploitation	Un tiers peut déployer, utiliser et mettre à jour sans dépendre d'une explication orale.	Dossier, sections 14 à 16	Les trois manuels complets et B2-A22	Étayé. Les secrets et valeurs personnelles sont volontairement absents.

Réserve et contrôle CI/CD à lire avant l'oral

CR-055 - accessibilité humaine

Les contrôles automatisés, clavier, focus, reflow, arbre d'accessibilité et zoom natif sont consignés dans B2-A36 et B2-A37. Deux vérifications ne sont pas présentées comme accomplies : une revue humaine exhaustive des contrastes sur fonds composites et un parcours complet avec un lecteur d'écran réel. Cette réserve interdit de transformer les résultats axe/Playwright en déclaration de conformité RGAA exhaustive.

CR-062 - chemin négatif CI vers CD fermé par B2-A38

B2-A38 consigne la CI courante 29856584668, volontairement rouge sur la pull request brouillon isolée #46. Après l'échec ESLint, les jobs de tests, build, E2E et Docker sont skipped, aucun run CD n'est associé au SHA et les inventaires Vercel de production API/Web restent strictement inchangés. Le test `pnpm test:cd-policy` passe 6/6 contrôles sur le YAML courant. CR-062 est donc clos par cette preuve négative, le chemin vert 29845956008 vers 29846343559 et la preuve historique. Sa limite reste explicite : aucun commit volontairement rouge n'a été poussé sur main, afin de ne pas dégrader la branche de production.

Vérification d'intégrité

Deux identités coexistent volontairement :

- b002adb identifie le code applicatif effectivement testé et déployé ;
- le SHA documentaire inscrit dans le MANIFESTE . txt identifie la consolidation

et la source remises au jury, sans prétendre qu'elles ont été redéployées.

Le MANIFESTE . txt du paquet est la référence finale pour les SHA complets, le nombre de pages et les empreintes SHA-256. En cas de divergence entre une copie de travail et le paquet, le paquet manifesté prévaut.

ORAL-02 - Script chronométré de soutenance

Durée cible : 14 minutes 30, hors questions.

Le candidat ne prononce aucune adresse électronique, aucun secret et aucune donnée de santé personnelle. Les données affichées sont dédiées à la recette.

Avant de commencer

Ouvrir uniquement les supports nécessaires : application, dossier principal, annexes, run CI 29845956008, run CD 29846343559 et MANIFESTE.txt. Fermer les consoles contenant des variables d'environnement. Vérifier que le zoom de présentation rend le texte lisible au jury.

Phrase d'ouverture à conserver :

« Je présente les preuves du Bloc 2 sur la baseline applicative b002adb.

Le bloc comporte neuf compétences, dont quatre éliminatoires. Je vais distinguer ce qui a été exécuté, ce qui est automatisé et l'unique réserve qui reste ouverte. »

Déroulé chronométré

0:00-0:45 - Cadre et fil conducteur

- Afficher la synthèse du dossier, section 2.
- Annoncer neuf compétences, quatre éliminatoires et 59 recettes : 58 closes, une réservée.
- Expliquer que chaque affirmation renvoie à une annexe, un run ou un manuel.

Transition : « Je commence par la chaîne qui rend l'application reproductible, puis je démontre les quatre compétences éliminatoires. »

0:45-2:00 - C2.1.1, architecture et environnements

- Montrer le schéma de la section 5 : Next.js vers API Hono, services, repositories, PostgreSQL/OpenAI.
- Citer Node 24, pnpm figé, PostgreSQL 16, Docker, Vercel et Neon.
- Donner trois mesures A29 : 150/150 réponses valides ; p95 Web 508,63 ms, API 339,66 ms et readiness 267,11 ms.
- Borner immédiatement la preuve : mesure séquentielle, sans charge distribuée et sans chronométrage d'une génération IA payante.

2:00-3:00 - C2.1.2, intégration continue

- Afficher le run 29845956008 et ses six jobs verts.
- Résumer les gates : lint, types, tests/couvertures, PostgreSQL réel, Playwright/axe, build, audit low et images Docker.
- Montrer que la CI porte exactement le SHA court b002adb.
- Citer B2-A38 : la CI courante 29856584668 échoue réellement sur la PR isolée #46, les jobs aval sont skipped, aucun CD n'est créé et les inventaires Vercel production restent inchangés ; test:cd-policy passe 6/6.

Phrase de précision : « Les suites complètes comptent 170 tests API, 55 Web, 14 shared et neuf contrôles PostgreSQL RNCP ; les rapports de couverture ont un sous-ensemble instrumenté, présenté séparément. »

3:00-5:00 - C2.2.1, prototype - éliminatoire

Parcours live minimal, sans création destructive :

1. ouvrir l'accueil connecté et annoncer la protection OAuth ;
2. ouvrir le formulaire de génération et montrer labels, validation et reflow ;
3. ouvrir un programme existant, changer d'onglet semaine au clavier ;
4. ouvrir une séance, démarrer puis mettre en pause le Timer ;
5. montrer le journal et le dashboard, puis les paramètres.

Si une opération réelle d'IA risque de ralentir l'oral, ne pas la lancer. Montrer le résultat existant et renvoyer à B2-A25/B2-A34 pour la création, la journalisation et le nettoyage réellement exécutés. Montrer ensuite les captures bureau/mobile B2-A30.

5:00-6:30 - C2.2.2, tests - éliminatoire

- Afficher le tableau de couverture de la section 8 et B2-A31.
- Expliquer un test par couche : contrat Zod partagé, service API, composant React et repository PostgreSQL avec ownership.
- Citer les lignes couvertes : shared 100 %, API 85,64 %, Web 69,04 % et PostgreSQL 93,70 %.
- Expliquer que les pages serveur non unitaires sont complétées par Playwright, sans gonfler artificiellement la couverture.

6:30-9:00 - C2.2.3, sécurité et accessibilité - éliminatoire

Sécurité :

- montrer B2-A35 ; citer ownership, validation Zod, requêtes paramétrées, secret interservice, CORS, CSP et audit de dépendances ;
- rappeler les exécutions SQL-like, XSS inerte, absence de secret dans le navigateur et refus d'une origine hostile ;
- annoncer les risques résiduels : rate limit en mémoire et CSP contenant encore `unsafe-inline`.

Accessibilité :

- montrer B2-A36/B2-A37 : 33/33 contrôles sur pages publiques/privées et zoom Chromium natif 16/16 à 200/400 % après correction ;
- citer reflow, clavier, focus, structure, alertes et arbre d'accessibilité ;
- dire exactement : « Ce résultat ne constitue pas une déclaration exhaustive de conformité RGAA. La revue humaine des fonds composites et le parcours avec lecteur d'écran réel restent ouverts. »

9:00-10:00 - C2.2.4, déploiement et versionnement

- Afficher le run CD 29846343559 : migration, API, smoke API, Web, smoke Web.
- Citer les réponses HTTP 200 et la readiness PostgreSQL/configuration IA ok.
- Distinguer le SHA applicatif b002adb du SHA documentaire f92a31e.

10:00-12:00 - C2.3.1, cahier de recettes - éliminatoire

- Afficher la matrice fonction → scénario → preuve du cahier.
- Donner le résultat exact : 58 scénarios clos sur 59.
- Montrer une recette nominale, une erreur et une sécurité : CR-016 génération, CR-015 panne IA et CR-043 XSS, par exemple.
- Présenter CR-055 comme l'unique réserve. Montrer que CR-062 est fermé par B2-A38, tout en disant qu'aucun commit volontairement rouge n'a été poussé sur main.

Phrase de cadrage : « Une réserve n'est pas transformée en succès. Elle indique le contrôle manquant, la preuve disponible et l'action qui permettrait de la fermer. »

12:00-13:00 - C2.3.2, correction des bogues

- Ouvrir le plan B2-A13.
- Raconter un cycle complet : reproduction d'une troncature à 400 %, correction par retour à la ligne, tests Web/typecheck/build, CI/CD puis contre-recette 16/16 en production.
- Citer aussi la correction des vulnérabilités brace-expansion et shell-quote documentée par B2-A27.

13:00-14:00 - C2.4.1, documentation d'exploitation

- Montrer les trois manuels : déploiement, utilisateur et mise à jour.
- Expliquer le parcours d'un exploitant : prérequis, variables sans valeur secrète, migrations, healthchecks, rollback et mise à jour.
- Montrer que les manuels sont inclus dans les annexes et dans l'archive source.

14:00-14:30 - Conclusion

« La baseline b002adb relie le prototype, les tests, la CI et le CD. Les quatre compétences éliminatoires ont des preuves primaires identifiées. Le dossier ne revendique ni audit RGAA exhaustif, ni rate limit distribué, ni replay négatif du workflow courant. Ces limites sont consignées dans les l'unique réserve CR-055 et dans les risques d'architecture. »

Afficher le manifeste, puis rendre la parole au jury.

Discipline de preuve pendant les questions

- Répondre d'abord par le résultat, puis par la preuve et enfin par la limite.
- Ne jamais dire « conforme RGAA » ; dire « contrôles exécutés sur le périmètre documenté ».
- Ne jamais attribuer le déploiement à f92a31e ; seul b002adb est la baseline applicative déployée.
- Ne pas additionner les tests instrumentés et les suites complètes.
- Si une page live diffère des captures, arrêter la démonstration live et appliquer le plan de secours au lieu d'improviser une explication.

ORAL-03 - Plan de secours de démonstration

Objectif : conserver une preuve compréhensible sans présenter une capture ou un résultat historique comme une observation live.

Préparation

Trente minutes avant l'oral

- contrôler l'accès à l'application et au compte de recette dédié ;
- appeler les healthchecks Web, API et readiness sans afficher de secret ;
- ouvrir les runs CI 29845956008 et CD 29846343559 ;
- ouvrir localement le dossier, les annexes, les captures B2-A30 et le MANIFESTE.txt ;
- vérifier que les PDF restent accessibles sans réseau ;
- fermer l'historique, les consoles et gestionnaires pouvant révéler une identité, un jeton ou une variable d'environnement.

Cinq minutes avant l'oral

- ne pas se déconnecter si la session dédiée est valide ;
- placer le Timer sur une séance de recette non sensible ;
- garder le cahier de recettes à CR-055 et ouvrir B2-A38 pour CR-062 ;
- basculer l'ordinateur sur secteur et couper les notifications.

Niveaux de démonstration

Niveau A - Production et OAuth disponibles

Exécuter le parcours live du script : accueil, génération sans appel IA obligatoire, programme, Timer, journal, dashboard et paramètres. Ne créer que des données de recette et les supprimer après l'oral si une création est nécessaire.

Niveau B - OAuth indisponible, production publique disponible

1. Montrer la redirection vers le fournisseur uniquement si elle fonctionne.
2. Dire : « L'obtention d'une nouvelle session n'est pas disponible maintenant ; je passe aux preuves horodatées, sans qualifier cette étape de live. »
3. Présenter B2-A24 pour le démarrage OAuth, B2-A25/B2-A34 pour le parcours authentifié et B2-A30 pour le rendu bureau/mobile anonymisé.
4. Poursuivre en live sur les pages publiques et les healthchecks.

Niveau C - Production indisponible, plateformes de preuve disponibles

1. Montrer que l'échec est externe au support local, sans tenter de modifier la production pendant l'oral.
2. Afficher la CI 29845956008, le CD 29846343559 et leurs SHA.
3. Montrer B2-A28 pour la chaîne CI/CD, B2-A38 pour la gate négative, B2-A29 pour les mesures de production, B2-A30 pour le prototype et B2-A34/B2-A35 pour les recettes finales.
4. Dire : « Ces éléments sont des preuves conservées de la campagne du 21 juillet 2026 ; ils ne prouvent pas la disponibilité à cet instant. »

Niveau D - Réseau entièrement indisponible

Utiliser uniquement le paquet local manifesté : dossier, annexes, captures, archive source et trois manuels. Montrer dans MANIFESTE . txt les SHA et empreintes. Ne pas lancer un serveur local non préparé, car son environnement ne serait pas la production b002adb démontrée dans le dossier.

Incidents et bascule probatoire

Incident	Décision immédiate	Preuves de remplacement	Formulation exacte
OAuth refuse ou expire la session	Ne pas saisir d'identité personnelle devant le jury ; passer au niveau B.	B2-A24, B2-A25, B2-A26, B2-A30, B2-A34	« L'authentification live est indisponible ; voici l'exécution horodatée et sa portée. »
L'API ou le Web renvoie une erreur	Capturer mentalement le code, ne pas redéployer ; passer au niveau C.	CD 29846343559, B2-A28, B2-A29, B2-A30	« La disponibilité actuelle n'est pas prouvée ; le dernier état conservé est celui-ci. »
Génération IA lente, quota ou 503	Ne pas relancer en boucle et ne pas exposer la clé.	B2-A25 pour la génération réelle ; B2-A34 pour retry, timeout et erreur 503	« Le fournisseur est une dépendance externe ; le comportement nominal et l'échec contrôlé ont chacun une preuve. »
GitHub Actions indisponible	Utiliser les annexes et le manifeste local.	B2-A28, docs/ci-cd.md, MANIFESTE . txt	« Le run n'est pas consultable live ; je n'en modifie ni l'identifiant ni le verdict consigné. »
Capture contenant une donnée personnelle	Fermer immédiatement la vue ; utiliser les captures anonymisées.	B2-A30	« Je retire cette vue et poursuis avec la preuve anonymisée prévue. »
Mise en page live différente de B2-A30	Ne pas affirmer l'équivalence ; montrer le SHA de la page si disponible, sinon arrêter le live.	Baseline b002adb, B2-A30, B2-A37	« Je ne peux pas rattacher cette vue à la baseline sans vérification ; voici la preuve gelée. »
Timer ou dialogue ne répond pas	Ne pas rafraîchir avant d'avoir expliqué la bascule.	B2-A25, tests Web de la CI, CR-025 à CR-029	« Je passe de l'observation live à la contre-recette conservée. »
Le jury demande le chemin CI rouge actuel	Présenter B2-A38 sans provoquer un nouvel échec pendant l'oral.	CI courante 29856584668 sur PR isolée #46, jobs aval skipped, absence de CD, inventaires Vercel inchangés, test:cd-policy 6/6	« CR-062 est fermé sur le workflow courant ; aucun commit rouge n'a été poussé sur main. »

Ordre minimal en cas de temps réduit

S'il reste moins de huit minutes, conserver dans cet ordre :

1. les quatre compétences éliminatoires ;
2. la baseline b002adb reliée aux runs CI/CD ;
3. les 58/59 recettes et l'unique réserve CR-055 ;
4. les trois manuels et le manifeste ;
5. les autres compétences dans la matrice de lecture, sans démonstration longue.

Après l'oral

- supprimer uniquement les données de recette créées pendant la démonstration ;
- ne pas supprimer les preuves historiques ni modifier le paquet remis ;
- consigner séparément tout incident live, avec heure, page et code d'erreur ;
- ne jamais réécrire une annexe datée pour lui faire décrire un événement postérieur.

ORAL-04 - Questions-réponses du jury

Trame de réponse : résultat, preuve, limite, prochaine action.

Les formulations évitent toute déclaration plus large que les contrôles réellement exécutés.

Questions sur les compétences éliminatoires

Comment prouvez-vous que le prototype est réellement fonctionnel ?

La recette authentifiée B2-A25 couvre séance, programme, Timer, journal, dashboard, paramètres, suppressions et déconnexion sur la production. B2-A30 ajoute six tests et des captures anonymisées bureau/mobile. CR-065 ferme le parcours post-déploiement. La preuve porte sur la baseline b002adb et sur les parcours cités, pas sur toute combinaison possible d'usage.

Pourquoi les nombres de tests ne sont-ils pas identiques partout ?

Deux périmètres sont publiés. Les suites complètes comptent 170 tests API, 55 Web, 14 shared et neuf contrôles PostgreSQL RNCP. Les rapports de couverture instrumentent 155 API, 43 Web, 14 shared et huit PostgreSQL. Le neuvième contrôle PostgreSQL est une recette SQL de sécurité hors instrumentation de couverture. Les deux séries ne sont donc ni contradictoires ni additionnables.

Une couverture Web de 69,04 % est-elle suffisante ?

Elle dépasse le seuil de majorité retenu et porte sur les composants et règles testables dans ce runtime. Les pages serveur difficiles à instancier restent visibles dans le rapport au lieu d'être exclues artificiellement. Les parcours de ces pages sont complétés par Playwright et les recettes de production. La couverture reste un indicateur, pas une preuve unique de qualité.

Êtes-vous conforme au RGAA ?

Je ne revendique pas une conformité RGAA exhaustive. B2-A36 consigne 33/33 contrôles sur trois pages publiques et cinq privées ; B2-A37 consigne 16/16 mesures de zoom natif à 200/400 % après correction. Axe, l'arbre d'accessibilité, le clavier, le focus et le reflow couvrent un périmètre utile, mais ne remplacent pas la revue humaine de tous les critères. Les contrastes sur fonds composites et un parcours avec lecteur d'écran réel restent ouverts dans CR-055.

Pourquoi 58 recettes closes sur 59 ne bloquent-elles pas votre remise ?

L'unique scénario réservé n'est ni caché ni marqué réussi. CR-055 borne les contrôles d'accessibilité humaine encore nécessaires. CR-062 est désormais clos par B2-A38, qui combine échec réel de la CI courante, absence de CD, inventaires Vercel inchangés et test de politique 6/6. Le cahier reste ainsi auditable. Je ne transforme pas ce ratio en décision d'acquisition ; cette décision appartient au jury.

Sécurité et architecture

Pourquoi le rate limiting n'est-il pas distribué ?

Le prototype applique un quota en mémoire et CR-048 vérifie le 429 avec Retry-After dans un processus. Ce contrôle protège localement mais ne garantit pas un quota global entre instances serverless ; CR-049 l'enregistre comme risque architectural hors dénominateur des recettes. L'industrialisation consisterait à utiliser un store partagé avec incrément atomique et expiration, puis à exécuter une recette concurrente multi-instance. Aucun rate limit distribué n'est revendiqué dans l'état remis.

Pourquoi la CSP conserve-t-elle unsafe-inline ?

La CSP de production bloque unsafe-eval, limite les origines et complète les autres headers ; B2-A35 en contrôle l'effet. unsafe-inline reste nécessaire à l'intégration actuelle et réduit la protection contre certaines injections : il est donc documenté comme risque résiduel, pas présenté comme bonne pratique aboutie. L'amélioration serait une stratégie de nonces ou de hashes compatible avec le rendu Next.js, suivie de tests sur chaque route et d'une CSP en mode report-only avant blocage.

Comment empêchez-vous l'accès aux données d'un autre utilisateur ?

Le Web transmet une identité issue de la session, l'API vérifie le secret interservice, puis les services et repositories filtrent les ressources par propriétaire. Les cas 403 et l'absence d'insertion sont couverts en API et sur PostgreSQL réel, notamment CR-022, CR-023, CR-031 et CR-032. Un identifiant envoyé librement par le navigateur n'est pas utilisé comme preuve d'identité.

Comment traitez-vous SQL injection et XSS ?

Les entrées sont validées par Zod et les requêtes Drizzle sont paramétrées. B2-A35 insère puis relit une chaîne SQL-like comme donnée tout en vérifiant que la table reste intacte. Des charges `script` et `img onerror` restent inertes au rendu React dans Chromium et Firefox. Ces recettes ciblées complètent la revue OWASP ; elles ne constituent pas un test d'intrusion exhaustif.

Que faites-vous des données liées à la santé ?

Les journaux et notes facultatives sont rattachés au compte et filtrés par ownership ; la notice de confidentialité décrit le traitement. Le dossier et les captures sont anonymisés, et les secrets restent hors navigateur et hors dépôt. Une industrialisation demanderait en plus une analyse réglementaire et de conservation adaptée au contexte réel de l'organisme exploitant.

CI/CD, versions et preuves

Quel SHA a réellement été déployé ?

Le SHA applicatif est `b002adb0e0e7d8d85ee493d54879e190d77d2078`. Il est relié à la CI `29845956008` et au CD `29846343559`. Le SHA `f92a31eda417bc42c79eb43ec6c588b0e72e6d94` correspond à la consolidation documentaire et à la source archivée dans le paquet ; il n'est pas présenté comme un nouveau déploiement. Le manifeste consigne les deux rôles.

Comment prouvez-vous qu'un échec de CI interdit le CD ?

B2-A38 exécute réellement la CI courante `29856584668` sur la pull request brouillon isolée #46. L'échec ESLint rend les jobs aval `skipped`, aucun run CD n'est associé au SHA et les inventaires Vercel production API/Web restent identiques avant/après. Le test `pnpm test:cd-policy` passe également 6/6 sur le YAML courant. Cette preuve négative ferme CR-062 et complète le chemin vert `29845956008` vers `29846343559`. La limite est volontaire : aucun commit rouge n'a été poussé sur `main`, afin de ne pas dégrader la branche de production.

Le paquet remis est-il reproductible et immuable ?

Le builder refuse un état Git suivi non propre, vérifie la présence des preuves, la limite de 30 pages du dossier, les trois manuels et l'archive source filtrée. Le paquet final contient un manifeste avec le SHA archivé et les empreintes SHA-256 de chaque pièce. Cela prouve l'intégrité de la remise ; la reproductibilité de l'environnement repose aussi sur Node 24, `pnpm` et le lockfile figé.

Quelle différence faites-vous entre CI et CD ?

La CI établit la qualité du commit : lint, types, tests, PostgreSQL, accessibilité automatisée, build, audit et images. Le CD ne commence qu'après ce succès : migration, déploiement API, smoke API, déploiement Web et smoke Web. Les runs canoniques sont respectivement `29845956008` et `29846343559`.

Choix et limites d'ingénierie

Pourquoi Next.js, Hono et Drizzle ?

Next.js structure l'interface et les actions serveur, Hono garde une surface HTTP légère avec des middlewares testables, et Drizzle fournit un schéma typé, des migrations et des requêtes paramétrées. La séparation contrôleurs, services et repositories isole les règles métier des transports et de PostgreSQL. Ce choix est documenté par les ADR et validé par des tests à chaque couche.

Vos mesures prouvent-elles la tenue en charge ?

Non. B2-A29 prouve 150/150 réponses valides sur trois routes et des objectifs p95 atteints depuis un poste, de façon séquentielle. Elle ne simule ni la concurrence distribuée ni le coût d'une génération IA réelle. Un test de charge future devrait définir profils, concurrence, seuils d'erreur, budget fournisseur et observation base/API/Web.

Que se passe-t-il si OpenAI est lent ou indisponible ?

L'appel reste côté serveur, avec validation de la sortie, timeout, retry borné et erreurs structurées. B2-A34 couvre les erreurs attendues, tandis que B2-A25 conserve une génération réelle et son nettoyage. Le plan de secours interdit de relancer en boucle ou d'exposer une clé pendant l'oral.

Quelle serait votre première amélioration avant une mise en production à grande échelle ?

Je prioriserais le rate limit distribué, l'observabilité centralisée et la réduction de la CSP unsafe-inline, puis je ferais CR-055 avec une campagne humaine d'accessibilité. Chaque changement devrait ajouter une recette mesurable, passer la même CI et être déployé progressivement avec rollback.

Que faites-vous si OAuth ou la production tombe pendant la soutenance ?

Je ne présente pas une capture comme une observation live. Le plan de secours distingue quatre niveaux : parcours live, pages publiques avec preuves OAuth horodatées, plateformes CI/CD avec annexes, puis paquet local manifesté sans réseau. B2-A24 à A26 et A30/A34 remplacent le parcours authentifié ; B2-A28/A29 remplacent l'observation de production. La formulation indique toujours la date et la portée de la preuve.

Les manuels sont-ils réellement utilisables par un tiers ?

Le paquet contient un manuel de déploiement, un manuel utilisateur et un manuel de mise à jour. Ils couvrent prérequis, variables sans valeur secrète, migrations, healthchecks, rollback, parcours métier et procédure de mise à jour. B2-A22 apporte l'exécution Docker/migration associée. Les valeurs d'exploitation propres à l'organisation restent volontairement à renseigner.